

ATOS FOR INTERNAL USE



TECHNICAL SECURITY SPECIFICATIONS SERVER
UNIX

AUTHOR(S) : Freek Verschuren
DOCUMENT NUMBER : MSP-GAD-0244
VERSION : 8.0
STATUS : Final
SOURCE : Atos
DOCUMENT DATE : 20-07-2021
NUMBER OF PAGES : 55

Role	Signature
Document Owner	X Mhatre, Sameer Global Service Architect
Reviewer	X Kamil Kilinski Global Operation Security Compliance Officer
Quality Assurance Function	X Santosh Kudtarkar Documentation Controller
Senior Manager	X Dorin Vlas Head of Risk Management and Control Framew...

Contents

Target readers, communication method	10
1 General Information	12
1.1 Purpose	12
1.2 Audience	12
1.3 Scope	12
1.4 Implementation of measures	12
1.5 Document maintenance and distribution	13
1.6 Related documents	13
2 Introduction	14
2.1 Risk Classifications	14
2.2 Deviations	15
3 Description of Measures	16
3.1 Authorization and Authentication	16
3.2 Logging	22
3.3 Monitoring	22
3.4 Network Security	26
3.5 Operational Security	28
Appendix A Checklist	54

List of changes

version	Date	Description	Author(s)
1.0	21-03-2014	Initial Version	Michael Young
1.1	22-04-2014	Small changes	Patrick Holt
1.2	16-05-2014	Updated version	Michael Young
1.3	19-05-2014	Final version	Patrick Holt
1.4	28-11-2014	Updates following the creation of scripts Deleted measure #00015. Deleted measure xxxYY.	Patrick Holt
1.5	17-12-2014	Changes in measure #00024 Added variable field	Patrick Holt
1.6	27-01-2015	Changed variable field into exception field	Patrick Holt
1.7	20-01-2015	Deleted measures: #00002, #00003, #00011, #00012, #00013, #00020, #00029. Updated measures: #00001: Title changed, max age 30 -> 90 #00005: Added background #00027: Title changed	Michael Young
1.8	09-02-2015	Updated measures: #00001: Title changed, max age 90 -> 92 #00005: Added background #00014: Added background #00027: Added background #00030: Added background	Patrick Holt
1.9	20-03-2015	Changed Senior Manager Atos name to David Bixler	Patrick Holt
2.0	24-03-2015	Final version	Patrick Holt
2.1	21-09-2015	Removed signature line for Global Tower Head	Patrick Holt
2.2	21-09-2015	Added extra text to section 1.4: "All exceptions to measures mandated by this document must be registered in the Atos Risk Tool (ART) and must be agreed by the Client Security Manager and the Customer."	Patrick Holt
2.3	13-10-2015	Added extra section "Document maintenance and distribution" Removed all references to MSM-GSS-0008 Changed GSS to BDS in the whole document	Patrick Holt
2.4	16-11-2015	Added Oracle Enterprise Linux to the scope	Michael Young

version	Date	Description	Author(s)
2.5	18-11-2015	Changed measure #0001: Changed max password age to 90 days Added maxweeks to 13 for Solaris Changed measure #0009: removed duplicate entries for "ensure root is owner /etc/lilo.conf and permissions are set to 600"	Patrick Holt
3.0	18-11-2015	Final version	Patrick Holt
3.1	19-10-2016	3SU00001 Changed max password age to 91 days (13 weeks) Hp linux and solaris removed old way to measure and added the way that all users that have a passwd are checked. Added exception for users that not use a local password (for example ssh key/passphrase) Changes "personal usernames" in "all users that have a password set" Changed/added the files to be checked	Freek Verschuren
3.2	17-11-2016	3SU00009 added bin as owner of /etc/default/security: 3SU00021 additional items 3SU00022 added USF method 2SU00023 added logfiles 2SU00024 small changes 3SU00028 rewritten (more items to check) 3SU00037 rewritten, new rules	Freek Verschuren
3.3	13-12-2016	3SU00007 (4SU00025) added the rule for admin accounts to 14 Changed all Measure ID form 3SU0000 to 4SU0000 SU00007 added min password length for administrators (to 15) New Measure IDs 4SU00038, 4SU00039 and 4SU00040	Freek Verschuren
3.4	16-12-2016	4SU00038 added root history 4SU00005 aix passwd restrictions 4SU00006 added the history period (aix) 4SU00008 added multiple syslog versions Created 4SU00041 Max Login Retries Created 4SU00042 Duplicate UID Created 4SU00043 Root path Textual updates Recreated Atos word house style	Freek Verschuren
4.0	16-12-2016	Final version	Freek Verschuren
4.1	24-12-2016	Changed all Measure ID form 4SU0xxx to 3SU0xxx and 2 SU0xxx Related documents: 2.1 Risk Classifications: added name convention	Freek Verschuren

version	Date	Description	Author(s)
		4SU00043 was duplicated Cron/AT allow is now 2SU00044 and moved to the end of the document	
4.2	24-12-2016	Corrected the risk Mismatches in measures 22,38, 39, 40, 41, 42 and Appendix A Removed 3SU00026 from check list	Freek Verschuren
4.3	10-03-2017	3SU00041 correct the linux measure 2SU00018 added or root 2SU00038 Minimal 2048 for all shells and added more explanation 2SU00022 changed 45 days to 30 days in the Measure 3SU00036 Changed seconds in milliseconds 3SU00001 7862400seconds=91 days = 13 weeks 3SU00044 added Linux and Solaris locations	Freek Verschuren
4.4	30-03-2017	3SU00004 for aix changed to /etc/security/passwd 3SU00021 changed some capital letters in small in the commands.	Freek Verschuren
4.5	21-05-2017	3SU00005 added remark for sun (MINNONALPHA) 3SU00004 grammatical correction 3SU00008 added multiple file locations of syslog configuration files 3SU00021 added Solaris 11 (ipadm) 2SU00022 grammatical correction and added logadm that is used in sun-os 3SU00034 added Solaris 11	Freek Verschuren
4.6	23-05-2017	2SU00006 corrected the Linux part 3SU00009 adjusted the hp-ux /tcb items	Freek Verschuren
4.7	22-06-2017	3SU00009 Added exception for /etc/security/mkuser. 3SU00025 only Sha512 remains as proper hash 3SU00041 changed unlock_time to lock_time 2SU00023 added lokations of cron log files	Freek Verschuren
4.8	13-07-2017	2SU00038 removed the personal logging, only root logging remains. 2SU00023 changed location of cron logging 3SU00025 only Sha512 remains as proper hash for REDHAT and SuSu	Freek Verschuren
4.9	24-08-2017	3SU00041 added pam_tally or pam_tally2 must be installed. Small textual corrections Layout changes 3SU00010 added /etc/profile.d/* 3SU00034 changed /etc/pam.d/system-auth to /etc/pam.d/* 3SU00037 added If nfs exports are required 3SU00025 described the RHEL7 part 3SU00009 Added /boot/grub2/grub.cfg 2SU00038 added bash 2SU00038 added "date" check 2SU00038 added document reference	Freek Verschuren

version	Date	Description	Author(s)
		3SU00001 removed personal 2SU00039 changed Background 3SU00041 added prerequisite hp 3SU00009 added /etc/security/mkuser.sys* 3SU00009 /etc/default/passwd added group sys (sun) 3SU00009 added /etc/pam.d/system-config-services 3SU00001 Insert Footnote corrected/added Reference	
5.0	24-08-2017	Final version	Freek Verschuren
5.1	24.01.2018	Updated signature field "Role" "Global Service Architect" to "Document Owner" to fulfill the requirements of "Atos document control".	M. Weise
5.2	06-02-2018	2SU00038 changes 8048 to 8000 Added line if no "\$USERNAME" is set Added additional example 3SU00028 split-up RPC processes Added ypserv,ypbind (nis rpc processes)	Freek Verschuren
5.3	10-04-2019	3SU00025 Updates for SUSE 15 releases changes Updated Measure id format to latest version. Quality assurance, final version. SU10001 added	Robert Roche Katarzyna Cieslak-Rylich
5.4	25-04-2019	Text rule changes "Must" and "should" are aligned SU00007 password length changed from 8 to 15 characters for all accounts Added other file for linux SU00022 add "auth" and "info" line Update the reference to documentation SU00023 added for aix and hp securing underlying directory as a alternative. SU00028 named ports and added: port 053 DNS/domain/bind port 023 telnet port 518 ntalk port 533 netwall port 543 klogin port 544 kshell port 762 quotad created SU00045 system account lockdown created SU00046 FTP warning Banner created SU00047 Disable user-mountable removable media (ie automountd). SU00048Disable USB services unless otherwise required created SU00049 Installation and access to scripting languages (PERL, CGI, etc. created SU00050 World-writable OS directories must have the sticky bit set	Freek Verschuren

version	Date	Description	Author(s)
		created SU00051 SSh HMAC algorithms created SU00052 SSh ciphers	
5.5	20-05-2019	SU00038 removed date check on aix (date is on ever row) SU00041 setting must be enabled for all users except root SU00033 added exception For aix hacmp SU00028 added exception For aix hacmp SU00018 added exception for applications that have own tss SU00041 added option pam_faillock.so final version	Freek Verschuren
5.6	27-06-2019	SU00022	Freek Verschuren
5.7	26-07-2019	Security final review SU00001 maximum age change for 90 days	M. Zabrocka
5.8	07-08-2019	Alcatraz Team review, R. Sinha review Value correction in SU00001 Rephrased SU00019, mis click correction in SU00022 New measure SU00053	M. Bułynko, F. Verschuren, M. Zabrocka
5.9	27-08-2019	SU00001 value for HP-UX changed for 7,776,000 Seconds, SU00038 HISTSIZE changed for 8000 SU00045 separator changed in implementation field for "," SU00049 minor change in TEST lines SU00001, SU00021, SU00023, SU00046, SU00050 spelling correction SU00007 removed part of Exception	M. Bułynko, F. Verschuren, M. Zabrocka
6.0	30-08-2019	SU00021 change wording in field Implementation SU00023 SUSE12 added SU00025 implementation specification for SUSE added Added SU00054 Bash ShellShock Added SU00055 Private ssh passphrase FINAL	Freek Verschuren
6.1	19-03-2020	SU00001, SU00045 added explanation no passwd for Aix SU00005 removed the versions redhad SU00006 Linux added additional test for individual users SU00007 implementation specification version for RHEL 8.x added SU00009 Linux /etc/passwd must be 644 not 664 SU00021 Added by on Linux "if exists" (some are not applicable on redhat 8) SU00023 removed redhat versions SU00023 textual correction	Freek Verschuren

version	Date	Description	Author(s)
		SU00025 implementation specification version for RHEL 8.x added SU00028 added ftp port 21, removed NIS, SU00028 added TCP/UDP where applicable. SU00035 added chrony as ntp solution for Linux SU00036 added chrony as ntp solution SU00037 added remark how solaris can be checked SU00041 implementation specification version for RHEL 8.x added SU00046 added correct file place for Aix SU00049 implementation specification version for RHEL 8.x added SU00050 excluded Nfs , added exception for applications having own TSS SU00051 added an example SU00052 added an extra example	
6.2	31-03-2020	SU00025 reviewed implementation specification version for RHEL 8.x SU00041 reviewed implementation specification version for RHEL 8.x SU00049 implementation specification version for RHEL 8.x added	Mahesh Pokhriyal
6.3	31-03-2020	Reviewed the document	Ritesh Sinha
6.4	14-04-2020	Security Review	M. Zabrocka
6.5	15-04-2020	Updated comments	Mahesh Pokhriyal
6.6	24-04-2020	Reviewed and changed Baseline References SU00006 textual updates to make sure "minimal" is understand correctly SU00007 accepted addition to ad or in etc/pam.d/system-auth SU00049 moved expiation for sap to Exception and removed remarks on a new measure SU00021 rejected/removed the suggestion to add toasca.conf to this measure	Freek Verschuren
7.0	22-05-2020	Final Quality assurance	M. Zabrocka m. Gondek
7.1	10-11-2020	Classification Prefix restored Final	M. Zabrocka
7.2	24-06-2021	SU00041: Reviewed and updated implement steps for SUSE SU00056: Added new Measure for Kex Algorithm Methods	Mahendrakumar.V
7.3	26-06-2021	Renames SU00056 to 2SU00056, removed table	Freek Verschuren

version	Date	Description	Author(s)
		Added 2SU00056 to check list, and some cosmetic changes	
7.4	30-06-2021	Security Review	M. Zabrocka
7.5	20-07-2021	3SU00041 system-auth was changed to ccommon-auth and added other Linux flavors to the SuSe part	Freek Verschuren
8.0	20-07-2021	Final	M. Zabrocka

Target readers, communication method

Target group	Distribution / publication method
Designers, architects and administrators tasked with validation and implementation of the security baselines.	The TSS documents are published by Atos Risk, Audit & Compliance Governance (RACG) on SharePoint https://sp2013.myatos.net/ms/gd/gadp/TSSD/

Terms and abbreviations

Terms / Abbreviations	Description
ART	Atos Risk Tool
ATLM	Atos Technology Lifecycle Management
BDS	Atos Big Data & Security Division
IDM	Atos Infrastructure & Data Management Division
ITCF	IT Control Framework
GOSCO	Global Operation Security Compliance Officer
RAGC	Risk, Audit and Compliance Governance
RAF	Risk Acceptance Form
RFC	Request for Comments
SLA	Service Level Agreements
TSS(D)	Technical Security Specifications (Document)

1 General Information

1.1 Purpose

A Technical Security Specification (TSS) is the document that can be seen as a result of the translation of the Atos IT Security Controls as described in the Security Baselines to specific Technical Security Controls.

This document holds the definitions of the security measures corresponding to the Technical Security Controls for a specific device or software area. The document contains details about how to configure the target devices and software and what needs to be validated for checking the compliancy to that measure.

The document also details on the risk classification and the data and data sources required for an IT Security Control. More info in document MSM-GSS-0009

1.2 Audience

This document is intended for designers, architects and administrators tasked with validation and implementation of the security baselines as per IT Security Control Framework.

The document assumes that the reader has reasonable understanding of the Security Compliance Process as well as familiarity with the devices/software mentioned in this document.

1.3 Scope

The scope of this Technical Security Specification covers the following:

1. All Unix Servers (AIX, HP-UX, Solaris)
2. All Linux Servers (Red Hat, SUSE Linux, Oracle Enterprise Linux)

The following areas are explicitly out of scope:

1. Windows Server
2. Network
3. Tooling
4. Application

1.4 Implementation of measures

The implementation of the TSS measures is mandatory for all target devices and software mentioned in the scope. In case of implementation in existing environments, TSS measures must be tested first in pre-production test environments following applicable change management processes before implementation in production.

Some of the measures in this document may affect compliance to industry specific regulations. In this case the security officer must approve the implementation or create an exception.



All exceptions to measures mandated by this document must be registered in the Atos Risk Tool (ART) and must be agreed by the Client Security Manager and the Customer.

1.5 Document maintenance and distribution

The TSS document, when approved, published and validated, becomes procedural to all referenced systems, services, applications or processes managed by Atos Managed Services following a 120 days grace period, during which an analysis of gaps, documentation of exceptions, and a plan to bring non-compliant systems into compliance must be developed.

The maintenance of the document is performed by the Global Service Architect. TSS documents will be reviewed minimally on an annual basis, unless technical or business requirements dictate updating sooner.

1.6 Related documents

This document is a subset of Atos Technology Lifecycle Management (ATLM) artefacts. Related documents are captured in below table.

Reference	Document Name
MSM-GSS-0001	Security Management Baseline
MSM-GSS-0002	Logical Security Baseline
MSM-GSS-0006	Server Security Baseline
ASM-SEC-0006	Password Policy
ASM-SEC-0001	ATOS INFORMATION SECURITY POLICY
TSS MeasureIDs (V...	Name conventions and allocated Measure ID's

Table 1: ATLM Related Documents

2 Introduction

The “Technical Security Specifications Server Unix” is a mandatory supplement to the existing Atos Security Policy and IT Security Controls. Its purpose is to increase security for IT systems and it must be implemented for all Atos managed devices. The measures and their priorities described here may be tightened and supplemented as necessary.

The TSS documents are published by Atos Global Architecture & Delivery Processes (GADP). The TSS itself is coordinated with reviewers from the Global Security Services and all relevant Atos Global Delivery units. It aims at providing sufficient detail to allow a qualified administrator to implement all measures.

To assist in documentation, a checklist for the manual validation process has been prepared as part of this TSS in appendix A.

Further assurance about the compliance of a device or software to the Atos IT Security Controls can be gained via a Scan on Demand as part of the Vulnerability Management Service offered Atos Big Data & Security (BDS).

2.1 Risk Classifications

CRITICAL

A security control is critical if it can be exploited by a remote attacker to gain access to the system, data or functionality when not implemented. All critical controls must be implemented before the equipment is installed in a production environment.

MODERATE

A security control is rated moderate if it can compromise data or functionality on the network equipment only if some other condition is met (e.g. a particular module or a user within a particular role is required). Moderate issue security bulletins typically include recommended actions to resolve the issue.

LOW

A security control is rated low if it is very difficult to exploit from outside or has a limited potential impact.

2.2 Deviations

Deviations to the measures must be corrected according to customer agreed Service Level Agreements (SLA). Atos will use default resolution targets for correcting the deviations that must be confirmed or changed by each customer.

Because correcting a deviation may impact the customer's business process, the analyst must decide whether or not the customer should be consulted. If the customer does not agree with correcting a deviation because doing so will negatively impact his business, a Risk Acceptance Form (RAF) has to be signed and handed over to formally transfer the associated risks to the customer. Atos will retain the right to accept or challenge the customer exception request.

3 Description of Measures

All measures in this document are categorized as MANDATORY. This categorization means that implementation is absolutely required. Exceptions other than those explicitly declared inside a measure require approval by DBS and GADP.

The key words "MUST", "MUST NOT", "REQUIRED", "SHALL", "SHALL NOT", "SHOULD", "SHOULD NOT", "RECOMMENDED", "MAY", and "OPTIONAL" in this document are to be interpreted as described in RFC 2119 (<https://www.ietf.org/rfc/rfc2119.txt>).

All measures are grouped into specific areas. The specific areas are chosen to combine measures where the IT Security Control can be divided into multiple measures, e.g. "Updates and Patches", "User Management and Access Control" and "Protocols and Services".

3.1 Authorization and Authentication

Measure ID	3SU00001
Measure Title	Password Maximum Age
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 - 2.1.15 ASM-SEC-0006 - 2.1.2, 2.1.4
Background	For User accounts, a maximum password age must be set.
Measure	All usernames must have a password age limit of at most 90 days. This measure applies only to usernames that can be authenticated with a password.
Implementation	Check applies only to users (except root) that have a local password set. It is a max value so less is allowed (0 (turn off) is not allowed) AIX: Check all usernames that have a password set using command "lsuser -a maxage ALL". Note that AIX maxage is specified in weeks, not days and a value of 0 means no expiration. A value of max 12 weeks is allowed If user is not configured in /etc/security/passwd, password is not set, so should not be checked. HP-UX: TCB: Check /tcb/files/auth/system/default u_exp min 7776000" Check all usernames using command "getprpw -m exptm [username]" Note -1 refers to the default listed in /tcb/files/auth/system/default. Shadow file: Check all usernames that have a password set using command "passwd -s user" Non trusted: Check all usernames that have a password set using command "passwd -s user" Linux: Check default maximum password age, "PASS_MAX_DAYS" from file /etc/login.defs Solaris:

	Check all usernames that have a password set using the individual entry in /etc/shadow and /etc/default/passwd for the default users.
	The value should be 90 days or less.
Exception	In cases where expiration of the root password can lead to service disruption, password aging can be disabled. In case a user does not have a password set (example users that uses ssh keys + passphrase) to log in password aging can be disabled.
First appearance	19-05-2014

Measure ID	3SU00004
Measure Title	Blank Passwords Are Not Allowed
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.5.7
Background	Blank (Empty) passwords are an unacceptable security risk.
Measure	All accounts that can be authenticated with a password must have a non-blank password. Also verify no legacy '+' entries exist in passwd, shadow, and group files.
Implementation	Do not permit blank passwords on user or administrative accounts. For OpenSSH: Ensure the following line is in the sshd_config file: PermitEmptyPasswords No For all operating systems: verify no legacy '+' entries exist in passwd, shadow, and group files AIX: Check accounts in /etc/security/passwd for a blank password HP-UX: Shadow solution: Check accounts in /etc/shadow for a blank password TCB solution: Check accounts in /tcb/files/auth/?/<username> for a blank password Non trusted solution Check /etc/passwd for a blank password Linux: Check accounts in /etc/shadow for a blank password Solaris: Check accounts in /etc/shadow for a blank password
Exception	
First appearance	19-05-2014

Measure ID	3SU00005
Measure Title	All passwords must match a certain level of complexity
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 - 2.1.6, 2.1.7 ASM-SEC-0006 - 2.1.1
Background	Complex passwords MUST be used in all cases, including mixed case, digits, and special characters. In addition to checking the system setting for complex passwords, the password settings for each user needs to be reported.
Measure	Complex passwords MUST be used in all cases, including mixed case, digits, and special Acceptable characters include the following: • Upper case letters • Lower case letters • Digits • Special characters At least 1 character of the above 4 groups MUST be used in the password.
Implementation	Linux (except RHEL 7): In /etc/pam.d/system-auth lcredit = -1 ucredit = -1 dcredit = -1 ocredit = -1 or minclass = 4 Linux (RHEL): /etc/security/pwquality.conf lcredit = -1 ucredit = -1 dcredit = -1 ocredit = -1 Also, check pam_pwquality.so is loaded in PAM modules SuSe: In /etc/pam.d/common-password lcredit = -1 ucredit = -1 dcredit = -1 ocredit = -1 or minclass = 4 Solaris: In /etc/default/passwd, ensure these directives are included: MINUPPER=1 MINLOWER=1 MINDIGIT=1 MINSPECIAL=1 Be aware that including MINNONALPHA results in an error to syslog and failure to change the password. MINNONALPHA is not allowed on sun

	AIX: In aix versions below 6.1 TL 8 (6100-08-00)) mindigit=1 minalpha=2 minother=2 Upper/Lower/Numerical cannot be enforced on AIX below 6.1 TL 8 (6100-08-00)) In AIX(7.1 (7100-00-00) as well as 6.1 TL 8 (6100-08-00)) and newer: In /etc/security/user, ensure these directives are included: mindigit=1 minloweralpha=1 minupperalpha=1 minspecialchar=1 minother=2 (mindigit + minspecialchar) minalpha=2 (minupperalpha + minloweralpha) HP-UX: In /etc/default/security, ensure these directives are included: PASSWORD_MIN_UPPER_CASE_CHARS=1 PASSWORD_MIN_LOWER_CASE_CHARS=1 PASSWORD_MIN_DIGIT_CHARS=1 PASSWORD_MIN_SPECIAL_CHARS=1 no exceptions may be listed in /var/adm/userdb/USERDB
Exception	Values specified are minimal values.
First appearance	19-05-2014

Measure ID	2SU00006
Measure Title	Previously Used Passwords (Password: History)
Classification	MODERATE
Baseline Reference	MSM-GSS-0002 - 2.1.11, 2.1.6 ASM-SEC-0006 - 2.1.1
Background	Previously used passwords cannot be immediately reused, as that bypasses the need to change the password. As a result, a history of passwords must be maintained to ensure they cannot be reused for a certain time. In addition to checking system configuration for password history, password settings for each user also need to be reported.
Measure	This measure applies only to usernames that can be authenticated with a password. to prevent re-use, a password history of 52 weeks must be maintained or to prevent re-use, a password history of at least 5 passwords and a Minimum password age of 1 day must be maintained.
Implementation	Linux: For the "password <any characters> pam_unix.so <any characters> remember=<numeric value>" entry in /etc/pam.d/system-auth, ensure the token Remember=5 (this the minimal value) In "/etc/login.defs", PASS_MIN_DAYS 1 (this the minimal value) Verify that all users PASS_MIN_DAYS maxdays _in /etc/shadow The 4th field PASS_MIN_DAYS must be 1 (or bigger) for all users with a password

	The 5th field maxdays must be 364 (or bigger) for all users with a password SuSe: In /etc/pam.d/common-password ensure these directives are included: <pre>pam_pwhistory.so remember=5</pre> (this the minimal value) In "/etc/login.defs", <pre>PASS_MIN_DAYS 1</pre> (this the minimal value) Solaris: In /etc/default/passwd, ensure these directives are included: <pre>HISTORY 5 MINWEEKS 1</pre> (this the minimal value) (this the minimal value) AIX: In /etc/security/user, ensure these directives are included: <pre>histsize 5 minage 1 or histexpire 52</pre> (this the minimal value) (this the minimal value) (this the minimal value) HP-UX: In /etc/default/security, ensure these directives are included: <pre>PASSWORD_HISTORY_DEPTH 5 PASSWORD_MINDAYS 1</pre> (this the minimal value) (this the minimal value) No exceptions may be listed in /var/adm/userdb/USERDB
Exception	
First appearance	19-05-2014

Measure ID	3SU00007
Measure Title	All passwords of all users must have a minimum length of 15 characters
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 – 2.1.6, 2.1.25, 2.1.26 ASM-SEC-0006 - 2.1.2, 2.1.4
Background	All passwords must have a minimum length.
Measure	All accounts must have a minimum length of 15 characters. This measure applies only to usernames that can be authenticated with a password.
Implementation	Check the "minimum password length" attribute (differs per OS), User with sudo and a set password must be min 15. AIX: Check the "minlen" entry of the default stanza in /etc/security/user. Additionally, all usernames must be checked using "lsuser -a minlen ALL". HP-UX: Check default minimum password length, "MIN_PASSWORD_LENGTH=15" from file /etc/default/security Untrusted server:

	Persons that have sudo access must be configured in /var/adm/userdb/USERDB to have minimal 15 characters. Trusted server: It is not possible to differentiate the min_password_length per users on a trusted server. Thus, all users are configured to 15 Linux: Check default minimum password length, "minlen" from file /etc/pam.d/system-authminlen or in etc/pam.d/system-auth minlen =15 (this will set the min password length to 15) RHEL8: Check default minimum password length, "minlen" from file /etc/security/pwquality.conf and /etc/pam.d/system-auth minlen =15 (this will set the min password length to 15) SuSe: Check default minimum password length, "minlen" from file /etc/pam.d/common-password minlen=15 (this must be set the min password length to 15) Solaris: Check Default minimum password length, "PASSLENGTH" from /etc/default/passwd (this must be set the min password length to 15)
Exception	Setting a minimum password length for specific user types is only possible with AIX. All other Operating systems [Solaris, hp-ux (trusted) and Linux] can only set a single password length affecting all users. On the operating servers that cannot set it for specific users a general setting of 15 must be configured.
First appearance	19-05-2014

3.2 Logging

Measure ID	3SU00008
Measure Title	Enable auth and info logging subsystem to log all auth events
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	The "auth" facility logs all authentication events, including "su". In order to successfully track user creation, logons, logoffs, privilege escalation and su activity, you need to enable the "auth" facility.
Measure	Logging for the auth and info facilities must be enabled in the syslog system.
Implementation	Depending of the syslog running on the server check the correct syslog configuration file. Ensure the syslog configuration file contains "auth" and "info" records. syslog /etc/syslog.conf rsyslog /etc/rsyslog.conf syslog-ng /etc/syslog-ng/syslog-ng.conf Ensure that the syslog is running correctly.
Exception	
First appearance	19-05-2014

3.3 Monitoring

Measure ID	3SU00009
Measure Title	Monitor System Files for Ownership and Permissions
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.5.5, 2.5.6
Background	Certain system files and directories need to be monitored to ensure changes do not affect the stability of the system. Incorrect protection and ownership can lead to loss of functionality (if too strict) and security exposure (if too permissive). Do not change the vendor-supplied settings unless there are compelling reasons to do so.
Measure	The following files and directories must have the respective ownership and permissions as described or stricter.
Implementation	Linux Bootloader: If using GRUB Bootloader: ensure root is owner /boot/grub/grub.cfg and permissions are set to 600 ensure root is owner /boot/grub/menu.lst and permissions are set to 600 ensure root is owner /etc/grub.conf and permissions are set to 600 ensure root is owner /boot/grub2/grub.cfg and permissions are set to 600 If using LILO Bootloader: ensure root is owner /etc/lilo.conf and permissions are set to 600 Linux: /etc/pam.d directory rights are 755 /etc/pam.d owner and group are root files within directory /etc/pam.d directory rights are 644 Except for /etc/pam.d/system-config-services permissions must be - rwxr-xr-x Ensure root is owner of /etc/passwd and permissions are set to 644

	Ensure root is owner of /etc/group and permissions are set to 644 Ensure root is owner of /etc/shadow and permissions are set to 400 Ensure that /usr/local/etc/rc.d/* is owned by root, and writable only by root AIX: /etc/security directory rights are 750 /etc/security owner is root and group owner is security. - files within directory /etc/security directory rights are 664. - Except for /etc/security/mkuser.sys* permissions must be -rwxr-x--- - Permissions of /etc/security/user must not allow any "other" access. /etc/security/passwd file rights are 600 Permissions. HP-UX: /etc/default/security directory rights are 755 /etc/default/security owner is root or bin and group is root, sys or bin /tcb directory rights are 551 /tcb owner is root or bin and group is root, sys or bin - All dirs in /tcb/files/auth/ must be 770 - Except for /tcb/files/auth/system permissions must be drwxrwx-x - All dirs in /tcb/files/auth/ must be owned by user root, group must be sys - All files in /tcb/files/auth/system/pwhist must be 600 Solaris: /etc/default/passwd directory rights are 755 /etc/default/passwd owner root and group root or sys - files within directory /etc/default/passwd directory rights are 644 For NFS: - Make sure that the access rights for the file /etc/exports (/etc/dfs/dfstab for both Solaris and Unix) are set to 644 and that the owner is root.
Exception	Stricter permissions are allowed
First appearance	19-05-2014

Measure ID	3SU00010
Measure Title	Actively Monitor System Files: /etc/profile
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	Changes to /etc/profile can grant root privilege to all users and must be actively monitored for any changes. If detected changes are approved, a mechanism to resolve diff hash mismatch needs to exist (checking into version control system, for example)
Measure	File /etc/profile must be actively monitored for changes
Implementation	Monitor files for unscheduled changes. Unix: /etc/profile linux: /etc/profile.d/* /etc/profile
Exception	

First appearance	19-05-2014
------------------	------------

Measure ID	3SU00014
Measure Title	Disallow Root login via SSH
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	A security hole could open on a server when direct login is allowed as root through ssh, because attempts can be made to brute force the root password and potentially get access to the system.
Measure	Remote login via a root account must not be allowed.
Implementation	Ensure that "PermitRootLogin no" is configured in sshd_config.
Exception	If root login is needed for cluster functionalities "permitrootlogin without-password" is also allowed.
First appearance	19-05-2014

Measure ID	3SU00016
Measure Title	SSH Protocol 2 Enforced
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.1.3
Background	Version 2 of the SSH protocol must be used. Version 1 is insecure and obsolete.
Measure	SSH protocol version 1 must not be used.
Implementation	Ensure "Protocol 2" is configured in the sshd_config file. Remark: In recent versions of OpenSSH, this is the default value and the keyword need not be present. Ensure there are no uncommented "Protocol" configuration lines with any protocol version 1 allowed. Do not assume protocol version 2 is the default unless the sshd version is confirmed to be OpenSSH 4 or newer.
Exception	
First appearance	19-05-2014

Measure ID	2SU00017
Measure Title	SSH "Rhosts" Functionality Disabled
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 2.5.13
Background	.rhost type functionality is insecure, even with SSH.
Measure	Rhost functionality must be disabled in SSH.
Implementation	Ensure "IgnoreRhosts yes" is configured in the sshd_config file. Remark: In recent versions of OpenSSH, this is the default value and the keyword need not be present.
Exception	
First appearance	19-05-2014

Measure ID	2SU00018
Measure Title	Home Directory Ownership
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 2.5.10
Background	Home directories need proper ownership to ensure that other users are unable to execute or access unauthorized programs or data.
Measure	Home folders and specific sub-folders must have proper ownership.
Implementation	Check that every .bashrc file present is owned by the owner (or root) of the home directory. Check that every .netrc file present is owned by the owner (or root) of the home directory. Check that every .profile file present is owned by the owner (or root) of the home directory. Check that every .telnetrc file present is owned (or root) by the owner of the home directory. Check that every home folder is owned by the assigned user (or root).
Exception	Applications might need Stricker or less strict home folders owner/group, for application folders see TSS of applications, if there is no application TSS this lines must be followed.
First appearance	19-05-2014

Measure ID	2SU00019
Measure Title	Home Directory Permissions
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 2.5.10
Background	Home directories need proper permissions to ensure that other users are unable to execute or access unauthorized programs or data.
Measure	Permissions of the home folders, and specific sub-folders must have proper permissions
Implementation	Check that every .bashrc file present has permissions of 744 or stricter Check that every .netrc file present has permissions of 600 or stricter Check that every .profile file present has permissions of 744 or stricter Check that every .ssh directory present, and its contents, has permissions of 700 Check that every .telnetrc file present has permissions of 600 or stricter Check that every home folder has its access rights set to 755 or stricter
Exception	Applications might need Stricker or less strict home folders, for application folders see TSS of applications, if there is no application TSS this measure must be followed
First appearance	19-05-2014

3.4 Network Security

Measure ID	3SU00021
Measure Title	Service Configuration: IP Stack settings SourceRouting, IpRedirects.
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	Managed endpoints must not run routing protocol daemons, nor allow bridged routing between network interfaces.
Measure	IP forwarding (routing) enabled. Parameters: AIX • ip6forwarding, • ipforwarding Linux • ip_forward HP-UX, SunOS • ip6_forwarding • ip_forwarding ICMP redirect packets required values: AIX: • ipignoreredirects • ipsendredirects HP-UX: • ip6_send_redirects • ip_send_redirects RedHat, SuSE: • accept_redirects • send_redirects SunOS: • ip6_ignore_redirect • ip_send_redirects • ip6_send_redirects • ip_ignore_redirect
Implementation	Check that any routing daemon is turned off on managed endpoints (RIP, OSPF, etc). Check that relevant network parameters are set to 0 (e.g. "ip6forwarding", "ipforwarding", "ip_forward", "ip6_forwarding", "ip_forwarding" depending on OS) AIX: • Check that "routed" and "gated" are configured not to run in /etc/rc.tcpip. Check that ip forwarding is disabled (set to 0) • /usr/sbin/no -o ipsrcrouteforward • /usr/sbin/no -o ipsrcrouterrecv • /usr/sbin/no -o ipsrcroutesend • /usr/sbin/no -o ip6forwarding, • /usr/sbin/no -o ipforwarding • /usr/sbin/no -o ipsendredirects • /usr/sbin/no -o ipignoreredirects (must be set to 1)

	HP-UX: • Check that the "mrouted", "gated", and "ramd" daemons are not running. • <code>ndd -get /dev/ip ip_forward_src_routed</code> • <code>ndd -get /dev/ip ip_forwarding</code> • <code>ndd -get /dev/ip ip6_forwarding</code> • <code>ndd -get /dev/ip ip6_send_redirects</code> • <code>ndd -get /dev/ip ip_send_redirects</code> Linux: • Check that the services, such as routed and radvd are not running, if found, record as non-compliance. To check bridged routing for both IPv4 and IPv6 traffic, look for the following entries are in <code>/etc/sysctl.conf</code>: • <code>net.ipv4.conf.all.accept_source_route=0</code> • <code>net.ipv6.conf.all.accept_source_route=0</code> • <code>net.ipv4.conf.all.forwarding=0</code> • <code>net.ipv6.conf.all.forwarding=0</code> • <code>net.ipv4.conf.all.accept_redirects=0</code> • <code>net.ipv6.conf.all.accept_redirects=0</code> • <code>net.ipv4.conf.all.secure_redirects=0</code> • <code>net.ipv6.conf.all.secure_redirects=0</code> * • <code>net.ipv4.conf.all.send_redirects=0</code> • <code>net.ipv6.conf.all.send_redirects=0</code> * • <code>net.ipv4.conf.all.ip_forward=0</code> * • <code>net.ipv6.conf.all.ip_forward=0</code> * (*) not applicable for SuSe. Solaris : • Check that the services: <code>in.routed</code>, <code>in.ripngd</code>, <code>in.ndpd</code>, <code>ripd</code>, <code>ripngd</code>, <code>ospfd</code> and <code>bgpd</code> are not running. If they are, record them as a non-compliance. Check that ip forwarding is disabled • <code>ndd -get /dev/ip ip_forward_src_routed</code> must be 0 • <code>ndd -get /dev/ip ip6_forward_src_routed</code> must be 0 • <code>ndd -get /dev/ip ip_forwarding</code> must be 0 • <code>ndd -get /dev/ip ip6_forwarding</code> must be 0 • <code>ndd -get /dev/ip ip6_ignore_redirect</code> must be 1 • <code>ndd -get /dev/ip ip_send_redirects</code> must be 0 • <code>ndd -get /dev/ip ip6_send_redirects</code> must be 0 • <code>ndd -get /dev/ip ip_ignore_redirect</code> must be 1 Check that ip forwarding is disabled on Solaris 11 • <code>ipadm show-prop -p _forward_src_routed ipv4</code> • <code>ipadm show-prop -p _forward_src_routed ipv6</code> • <code>ipadm show-prop -p forwarding ip</code> • <code>ipadm show-prop -p send_redirects ipv4</code> • <code>ipadm show-prop -p send_redirects ipv6</code> • <code>ipadm show-prop -p _ignore_redirect ipv4</code> • <code>ipadm show-prop -p _ignore_redirect ipv6</code>
Exception	At least AIX clusters require routing services. If using an AIX cluster, then an exception can be granted. Note that source routing must still be disabled.

First appearance	19-05-2014
------------------	------------

3.5 Operational Security

Measure ID	2SU00022
Measure Title	Log Data Retention: System Logs (syslog)
Classification	MODERATE
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	System logs are to be retained at least for 30 days.
Measure	It is recommended that daily syslog logs are kept for a month and versioned each day, rather than weekly or monthly log files.
Implementation	For systems that have the log rotate utility's like logadm or logrotate, ensure that the rotation is configured retain logs for minimal 30 days. Ensure the syslog configuration line that contains "auth" and "info" records - Is configured in weeks minimal 5 weeks must be stored on the server - Or is configured in days minimal 30 days must be stored on the server Example 1 With a cron job, call logrotate, using this as a baseline logrotate.conf configuration file. Usually, changing the "weekly" parameter to "daily" and the "rotate 4" to "rotate 30", it will accommodate the requirement. <pre># rotate log files daily daily # keep 30 days' worth of backlogs rotate 30 # create new (empty) log files after rotating old ones create # uncomment this if you want your log files compressed Compress</pre> Example 2 (USF) Daily entry in root crontab: <pre>/bin/rotateFile.pl > /appl/usf/log/rotate.log 2>&1</pre> The file: <pre>/appl/usf/filemgt/local/syslogd.xml</pre> Contains: <pre><file name="/var/adm/syslog/*"> <schedule>day</schedule> <keep>30</keep></pre> Example 3 <pre>via /etc/syslog.conf (min configuration) *.info [local location] rotate time 1d files 30 compress or auth.info [local location] rotate time 1d files 30 compress or auth.* [local location] rotate time 1d files 30 compress or</pre>

	*.info;mail.none /var/adm/syslog/syslog.log rotate time 1d files 30 compress (preferred)
Exception	
First appearance	19-05-2014

Measure ID	2SU00023
Measure Title	Crontab file ownership
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 2.5.14
Background	The permission of UNIX files/directories
Measure	Permissions for user's crontabs are set to 600 or stricter and the owner is set to the user or root.
Implementation	System crontab: For all files in /etc/cron.d/*, ensure crontab files are only owned by user root and group root. For all files in /etc/cron.d/*, ensure crontab files are only writable by root. User crontabs: User crontabs (in /var/spool/cron or /var/spool/cron/crontabs) must be owned by the user or root. Ensure that the files in /var/spool/cron/crontabs are set to 600 or stricter Ensure that the log files are not readable by normal users Either via directory (750 or stricter) either via log-files (640 or stricter) Default locations of log files REDHAT SUSE10,11 /var/log/cron (640 or stricter) Or Check if directory /var/log/ have 750 permissions or stricter (user and group: bin, cron, or root) SUSE12 (and newer versions) Check if file /var/log/messages is 640 (or stricter) Or Check if directory /var/log/ have 750 permissions or stricter (user and group: cron, bin or root) AIX,HPUX Check if file /var/adm/cron/log is 640 (or stricter) Or Check if directory /var/adm/cron/ have 750 permissions or stricter (user bin group cron) SOLARIS Check if file /var/cron/log is 640 (or stricter) Or Check if directory /var/cron have 750 permissions or stricter (user and group: cron, bin or root)

Exception	
First appearance	19-05-2014

Measure ID	2SU00024
Measure Title	Ownership: root umask
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	The permission of newly created UNIX files/directories is determined by the umask of the root user.
Measure	Root umask must be 022 or stricter. Preferable is 027 but this is not workable for all Unix flavors.
Implementation	Check: su - -c umask umask to 022 or stricter
Exception	
First appearance	19-05-2014

Measure ID	3SU00025
Measure Title	OS password encryption
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 2.1.13
Background	Encrypting passwords requires strong encryption.
Measure	The use of Sha512 or blowfish encryption is needed.
Implementation	SUSE (older than 15): - set the password algorithm in /etc/default/passwd CRYPT_FILES=sha512 Or CRYPT_FILES=blowfish SUSE 15 (and newer versions) - set the password algorithm /etc/login.defs ENCRYPT_METHOD SHA512 Or ENCRYPT_METHOD blowfish REDHAT: - set the password algorithm in /etc/sysconfig/authconfig PASSWDALGORITHM=sha512 Or PASSWDALGORITHM=blowfish RHEL7: - set the password algorithm /etc/sysconfig/authconfig PASSWDALGORITHM=sha512

	Or PASSWDALGORITHM=blowfish - In /etc/pam.d/system-auth (and password-auth) The line for pam_unix.so in the password section of the files must include sha512 or blowfish as an argument - set the password algorithm /etc/login.defs ENCRYPT_METHOD SHA512 Or ENCRYPT_METHOD blowfish RHEL 8: - In /etc/pam.d/system-auth (and password-auth) The line for pam_unix.so in the password section of the files must include sha512 or blowfish as an argument - set the password algorithm /etc/login.defs ENCRYPT_METHOD SHA512 Or ENCRYPT_METHOD blowfish AIX: - set the password algorithm in /etc/security/login.cfg pwd_algorithm = ssha512 or pwd_algorithm = blowfish HP-UX: - set the password algorithm in /etc/default/security CRYPT_DEFAULT=6 - To support changing the encryption algorithm on hp additional actions are needed, example on 11i v3 (11.31) systems, the Password Hash Infrastructure for HP-UX 11i v3 (PHI11i3) package must be installed if using /etc/shadow Install LongPassword11i3 Solaris: - set the password algorithm in /etc/security/policy.conf CRYPT_DEFAULT=6
Exception	HP-UX 11i v1 (11.11) and 11i v2 (11.23) do not support changing the encryption algorithm Hp-ux and solaris does not support blowfish
First appearance	19-05-2014

Measure ID	2SU00027
Measure Title	Disable SAMBA on all Unix systems unless needed
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	Samba is a tool used for the sharing of files and printers between Windows and UNIX operating systems. It provides access to sensitive files and, therefore, poses a security risk if compromised.
Measure	SAMBA must be disabled if not required
Implementation	Make sure the smb processes are not listening

	<i>ps -ef grep -e mbd -e amba</i> Forbidden process names: smbd nmbd Samba
Exception	
First appearance	19-05-2014

Measure ID	3SU00028
Measure Title	Service Hardening: Disable 'R' daemons and Telnet daemon
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.3.1 and MSM-GSS-0002 2.1.12
Background	The number of TCP/IP and UDP/IP ports listened on by a system must be kept as low as possible. This implies that daemons listening on IP ports must run only if they are specifically required, and not because the OS vendor enables them by default. The same holds for ports that are handled not by separate daemons, but by inetd. For detailed information see internet, and vendor documentation.
Measure	All remote management daemons (chargen, cmsd, comsat, ftp, daytime, discard, dns, dtspc, echo, finger, fingerd, netstat, rexd, rexec, rlogin, rprint, rquotad, rsh, rstatd, rusersd, rwalld, sadmind, sprayd, systat, talkd, time, telnet, ttdbserver, uucp, uucpd, ftp, snmp, etc) must be disabled. DNS Print spooler daemons and bind must not run, except on systems where required for service delivery.
Implementation	Disable all unsecure daemons (rlogin, rsh, rexec, telnet, etc) also check in /etc/inetd.conf, /etc/xinetd.conf and /etc/xinetd.d/* Forbidden listening TCP and forbidden open UDP processes: port 7 echo port 9 discard port 11 systat port 13 daytime port 15 netstat port 19 chargen port 20 ftpServer port 21 ftp port 23 telnet port 25 smtp Sendmail except listening to local host port 37 time port 42 NameServer port 53 DNS/domain/bind port 69 tftp port 79 finger port 109 pop2 port 110 pop3 port 143 imap port 161 SNMP port 220 imap3 port 512/tcp exec port 512/udp biff

	port 513/tcp login port 513/udp who port 514/tcp cmd port 514/udp syslog port 515 printer port 517 talk port 518 ntalk port 533 netwall port 540 uucp port 543 klogin port 544 kshell port 762 quotad port 6112 dtspcd Forbidden RPC service: Cmsd Rexd Rquotad Rstatd Rusersd Rwalld Sadmind Sprayd Ttdbserver Ypserv Ypbind
Exception	r-services are allowed if needed by clusters. TFTP must not be enabled, except where required for system management purposes (e.g., on a boot/install server) DNS (53) may listen remote only on dedicated DNS servers port 161 SNMP can be suppressed if needed on clusters like hacmp
First appearance	19-05-2014

Measure ID	2SU00030
Measure Title	Service Hardening: Disable Sendmail / MTA Unless Needed
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 – 2.5.3
Background	Disable email server if possible. Running Sendmail in "daemon mode" (with the -bd command line option) is only required on machines that act as mail servers, receiving and processing email from other hosts on the network.
Measure	Sendmail must be disabled unless needed.
Implementation	Check that port 25 is not listening from outside and no sendmail process are running.
Exception	
First appearance	19-05-2014

Measure ID	2SU00031
Measure Title	Service Hardening: Disable NIS
Classification	MODERATE
Baseline Reference	No reference to Security Baseline.
Background	Do not use NIS, and migrate to secure solutions such as LDAPS/Kerberos or NIS+.
Measure	NIS must be disabled.
Implementation	Deactivate NIS and migrate to secure solutions. All current Unix/Linux versions support LDAPS/Kerberos. NIS+ can only be used on Solaris and HP-UX systems.
Exception	
First appearance	19-05-2014

Measure ID	3SU00032
Measure Title	Service Hardening: SNMP Community Names
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 2.2.7
Background	Public and Private SNMP Community Strings must be changed prior to a network device being installed on the network. No default community strings are permitted.
Measure	The community strings "public" and "private" must be changed
Implementation	Check SNMP configuration file to ensure "public" and "private" are not being used as community names.
Exception	Default Atos policy states that SNMP shall not be used. However, if an exception is granted, this control must be checked.
First appearance	19-05-2014

Measure ID	3SU00033
Measure Title	Service Hardening: SNMP Version
Classification	CRITICAL

Baseline Reference	MSM-GSS-0002 2.2.8
Background	If required, SNMPv2 or greater shall be used for managing and monitoring of servers to guarantee data integrity and security. Note that there is no easy way to enforce use of SNMPv2 so even though SNMPv2 is required, this measure is still required.
Measure	Ensure SNMP v2 is used, if needed.
Implementation	AIX: Force use of SNMPv2 with this command "snmpv2_ssw -n" used in init script All other globally supported variants of unix use Net-SNMP, allowing for a common check. RHEL Ensure all "group" definitions in snmpd.conf are using "v2c" rather than "v1". SLES: Ensure all "group" definitions in snmpd.conf are using "v2c" rather than "v1". Solaris: Ensure all "group" definitions in snmpd.conf are using "v2c" rather than "v1". HP-UX: Ensure all "group" definitions in snmpd.conf are using "v2c" rather than "v1".
Exception	Default Atos policy states that SNMP shall not be used. However, if an exception is granted, this control must be checked. For aix hacmp have group v1 this is allowed as it is set by supplier and may not be changed
First appearance	19-05-2014

Measure ID	3SU00034
Measure Title	Ensure .rhost authentication is disabled in PAM
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.5.13
Background	RHOST authentication is not permitted on Unix machines. This includes PAM.
Measure	Verify that "pam_rhosts_auth.so" is not found in any PAM configuration. Ensure that users do not have .rhost files in their home directory.
Implementation	AIX: ensure pam_rhosts_auth is not in /etc/pam.conf Linux: ensure pam_rhosts_auth.so is not in /etc/pam.d/* HP-UX: ensure pam_rhosts_auth.so is not in /etc/pam.conf Solaris: ensure pam_rhosts_auth.so is not in /etc/pam.conf Solaris 11:

	Remove all of the lines that include rhosts_auth.so.1 from the PAM configuration file(s) that are stored in /etc/pam.d
Exception	
First appearance	19-05-2014

Measure ID	3SU00035
Measure Title	Ensure NTP Client is running on all Unix Computers
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.3.2
Background	All computers must synchronize time with a reliable clock source. The NTP service must be started on all computers. Usually, some custom configuration file tweaking is also required, such as specifying customer-specific NTP clock sources.
Measure	The NTP service must be started on all computers.
Implementation	Check if NTP daemon is running (ntpd or xntpd). Aix: /usr/sbin/xntpd -x HP: /usr/sbin/ntpd -x or /usr/sbin/xntpd -x Linux: ntpd or chronyd Solaris: ntpd or xntpd
Exception	For AIX wPARs, time is managed by the host, and should not be running on the wPAR. For SUN virtual the time is managed by the host thus should not be running on the virtual.
First appearance	19-05-2014

Measure ID	3SU00036
Measure Title	Ensure NTP clock does not drift significantly from a trusted time source
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.3.2
Background	Monitor clock of Unix server to ensure it does not drift too far from a trusted/configured time source. The agreed maximum drift is set to 300 milliseconds
Measure	Use monitoring tooling to collect Unix server local time and compare it to a trusted/configured time source. Enable “time skew” monitoring with tools Nagios or other respective tooling.
Implementation	Alternatively, check the status of NTP peers (ntpq -c peers). The time difference against a specific peer can be checked by verifying the value on the last line of the output of: <pre>ntpdate -duv timeserveripaddress</pre> if using chronyc use: <pre>chronyc -n sources chronyc ntpdata <ntpserver></pre> Alternatively, check the status of NTP peers (ntpq -c peers). The time difference against a specific peer can be checked by verifying the value on the last line of the output of: <pre>ntpdate -duv timeserveripaddress</pre>
Exception	
First appearance	19-05-2014

Measure ID	3SU00037
Measure Title	Verify that NFS, if used, is configured securely
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.5.16
Background	Exports without restrictive access control enable downloading confidential information and import of malicious software.
Measure	If nfs exports are required, the shared folders must have access control. The rights to all exported folders must be checked regularly, in order to determine whether access is limited to authorized network users and groups.
Implementation	If NFS is used on the system, please proceed via the following measures: • If possible, only allow read-only access to your exported data (-ro) • Do not export the root folder / or /etc • Deactivate NFS, if you do not wish to export any file systems. • Access to NFS exports must be restricted to specified hosts • If zfs filesystems are present, check also their attributes do not configure them to be shared over NFS. • Use the -nosuid option for mounting folders, to prevent execution of setuid programs.

	Use the <code>--nodev</code> option for mounting folders, to prevent the sharing of device files. Sun mount points are showed as Nosetuid nodevices Other looks like: Nodev and nlsuid.
Exception	
First appearance	19-05-2014

Measure ID	2SU00038
Measure Title	Logging and timestamps for issued commands
Classification	MODERATE
Baseline Reference	ASM-SEC-0001 - 3.9 MSM-GSS-0001 - 2.6.5
Background	When root issue commands in a shell session, those commands must be logged and timestamped. If a user becomes root the commands used must be logged in a history file traceable to the individual.
Measure	Implement logging and timestamps for all shell-level commands issued by root. Implement a personal history file for users who <code>su -</code> to root. Minimal 8000 entered commands must be stored in the history file of root.
Implementation	Classic shells: for the <code>~root/.profile</code> includes a personalized history file: <pre># set up individual history/stuff trap "echo 'logout root' " 0 9 USERNAME="/usr/bin/who am i /usr/bin/awk '{ print \$1}'" if [! -z "\$USERNAME"]; then USERPROFILE=/home/\$USERNAME/.profile HISTFILE=\$HOME/.sh_history.\$USERNAME if [-r \$USERPROFILE]; then . \$USERPROFILE fi HISTFILE=\$HOME/.sh_history fi HISTSIZE=8000 export HISTFILE HISTSIZE print -s `date`</pre> or: <pre>USERNAME=`who am I 2> /dev/null  awk '{print \$1}'` HISTFILE=/root/.sh_history\${USERNAME:+.}\$USERNAME} HISTSIZE=8000 export HISTFILE HISTSIZE</pre> Linux, suse, sun, hp: [check: the line <code>HISTFILE=</code> contains <code>\$USERNAME</code>] [check: the line <code>HISTSIZE=</code> contains 8000 or more] [check: the line <code>"print -s `date`"</code> exists] AIX: [check: the line <code>HISTFILE=</code> contains <code>\$USERNAME</code>]

	[check: the line HISTSIZE= contains 8000 or more] Bash: <pre>~root/.bashrc ... includes a personalized history file # set up individual history/stuff trap "echo 'logout root' " 0 9 USERNAME=`/usr/bin/who am i /usr/bin/awk '{ print \$1}'` if [! -z "\$USERNAME"]; then USERPROFILE=/home/\$USERNAME/.profile HISTFILE=\$HOME/.sh_history.\$USERNAME if [-r \$USERPROFILE]; then . \$USERPROFILE fi HISTFILE=\$HOME/.sh_history fi HISTSIZE=8000 HISTTIMEFORMAT='%F %T ' export HISTFILE HISTSIZE HISTTIMEFORMAT [check: the line HISTFILE= contains \$USERNAME] [check: the line HISTSIZE= contains 8000 or more] [check: HISTTIMEFORMAT is configured]</pre>
Exception	for normal users, it is advisable to add the time format and to enlarge the hist size, but this is not enforced, only the Atos tooling should check commands with root privileges for example, find these lines in ~/.bash_profile: <pre>HISTTIMEFORMAT="%d/%m/%y %T " HISTSIZE=2048 HISTFILESIZE=2048</pre> On aix all lines have a date check so date can be skipped on aix
First appearance	13-12-2016

Measure ID	2SU00039
Measure Title	Login Banners
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	In some legal jurisdictions it can be impossible to prosecute and illegal to monitor malicious users unless they have been notified that they are not From a security point of view, rather than legal, a login banner must not contain any specific information about the firewall name, model, software, or ownership.
Measure	Look for certain keywords, phrases, and variables in the banner file.
Implementation	Make sure that a banner is showed be for login Sshd_config must contains: Banner /etc/issue The file /etc/issue must contains at least:

	Warning: Access for authorized persons only. Additions in one or multiple languages are allowed for example: Waarschuwing: Toegang uitsluitend voor geautoriseerde personen.
Exception	
First appearance	13-12-2016

Measure ID	3SU00040
Measure Title	Service Hardening: Sendmail
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.5.3
Background	Smtp vrfy/expn must be blocked
Measure	Sendmail must configured if running
Implementation	Only if sentmail is listening: SMTP expn command is blocked (sendmail.cf option PrivacyOptions contains goaway or noexpn) SMTP vrfy command is blocked (sendmail.cf option PrivacyOptions contains goaway or novrfy)
Exception	
First appearance	13-12-2016

Measure ID	3SU00041
Measure Title	Max Login Retries
Classification	CRITICAL
Baseline Reference	ASM-SEC-0006 - 2.1.1 MSM-GSS-0002 2.1.10
Background	Accounts must include lockout, after incorrect login attempts. Auto reset is allowed but only after 30 minutes manual reset is also allowed.
Measure	Accounts must include lockout, after at least 5 incorrect attempts, and at most 10 incorrect attempts. Auto enabling is allowed after 30 minutes
Implementation	This setting must be enabled for all users except root RHEL (except RHEL8): - In /etc/pam.d/system-auth, ensure the token - deny (min 5 max 10) - unlock_time (min 1800 or missing) - pam_faillock.so or pam_tally or pam_tally2 must be installed. RHEL 8: - In /etc/pam.d/system-auth and /etc/pam.d/password-auth, ensure the token - deny (min 5 max 10) - unlock_time (min 1800 or missing) - pam_faillock.so or pam_tally or pam_tally2 must be installed. SuSe Debian, Ubuntu: - In /etc/pam.d/common-auth ensure the token - deny (min 5 max 10) - unlock_time (min 1800 or missing) auth required pam_tally2.so deny=5 unlock_time=1800 Solaris: In /etc/default/login, ensure these directives are included: - RETRIES (min 5 max 10) AIX: In /etc/security/user, ensure these directives are included: (for default) loginretries (min 5 max 10) (for all other users) loginretries (min 5 max 10) (or missing) HP-UX: Trusted: - In /tcb/files/auth/system/default ensure these directive is included: - u_maxtries (min 5 max 10) - per user check that there are no exceptions existing (min 5 max 10) with: /usr/sbin/getprpw -m umaxlntr [username] - prerequisite: "This attribute is enforced in the pam_hpsec service module, and requires that the pam_hpsec module be configured in /etc/pam.conf. See pam_hpsec(5) Shadow mode: - In /etc/default/security ensure these directive is included:

	○ AUTH_MAXTRIES (min 5 max 10)
Exception	The root user may be excluded for this rule.
First appearance	16-12-2016

Measure ID	2SU00042
Measure Title	Duplicate UID/GID
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 – 2.5.8
Background	Users and groups must have a unique Identifier Users must have a resolvable primary group.
Measure	Make sure all UID on a system are unique Make sure all GID on a system are unique Make sure that all users are member of an existing Group Verify that no UID 0 accounts other than root exist.
Implementation	Check /etc/passwd, /etc/group and is available any other users (link in an AD)
Exception	
First appearance	16-12-2016

Measure ID	2SU00043
Measure Title	Root path
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 – 2.5.9
Background	The PATH of root may not contain any directories that provide write access to other users. Only system directories (e.g. /bin, /user/bin) may be included in the PATH of root.
Measure	Ensure there are no '.' in root's path Ensure there are no group/world-writable directories in root's path. (group is only allowed if it is root bin or usf) Ensure there are no directory in root's path that are not owned by root, bin or usf
Implementation	Check the permissions listed with: su - -c echo \$PATH
Exception	
First appearance	16-12-2016

Measure ID	2SU00044
Measure Title	Cron/AT allow
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 – 2.5.14
Background	Restrict at and cron to authorized users
Measure	The use of cron.allow is preferred over cron.deny as this means that all new users are denied access to cron unless the permission is explicitly given in cron.allow The use of at.allow is preferred over at.deny as this means that all new users are denied access to at unless the permission is explicitly given in at.allow
Implementation	AIX , HP-UX: /var/adm/cron/cron.allow /var/adm/cron/at.allow Linux(Redhat,Suse): /etc/cron.allow /etc/at.allow Solaris: /etc/cron.d/cron.allow /etc/cron.d/at.allow
Exception	
First appearance	16-12-2016

Measure ID	2SU00045
Measure Title	System Account Default Passwords/ lockdown
Classification	MODERATE
Baseline Reference	MSM-GSS-0002 2.1.5
Background	disables direct login access for the daemon user accounts.
Measure	This change disables direct local and remote login to the daemon user account. It is recommended that a password is not set on this account to ensure that the only access is via su from the root account. There should not be a requirement to log in as the daemon user directly. All users should be given unique logon ids to ensure traceability and accountability.
Implementation	This change needs to be done for the following users (if exist on server): adm, bin, daemon, lp, mysql, nuucp, postgres, smmsp, nobody, sys, upnp, uucp, zfsnap, lpd, sys, guest, invscout, snapp AIX: To remove the default passwd: echo "[username]:*" chpasswd -c -e Change the login and remote login user flags to disable daemon user access: chuser login=false rlogin=false [username] Check for set password in /etc/security/passwd Check:

	Audit: Ensure remote access has been disabled for the daemon user: <pre>lsuser -a login rlogin [username] login=false rlogin=false</pre> Check if password is /etc/security/passwd <pre>sudo grep -p ^[username]: /etc/security/passwd ("password = *" or missing)</pre> If user is not configured in /etc/security/passwd, password is not set, so should not be checked. HP: Trusted server: <pre>/usr/sbin/modprpw -e [username] /usr/sbin/modprpw -m alock=yes -k [username]</pre> Edit the TCB file to remove the password None trusted server: <pre>passwd -l [username]</pre> Edit the shadow file to remove the password Check <pre>/usr/sbin/getprpw User name</pre> Check shadow/tcb file for set password Linux: <pre>passwd -l [username] chage -E0 [username]</pre> Edit the shadow file to remove the password Check: <pre>passwd --status [username] chage -l [username]</pre> Check shadow file for set password Sun: To lock a single account, use the command: <pre># passwd -d [username] # passwd -l [username]</pre> To configure a single account to be non-login, use the command: <pre># passwd -d [username] # passwd -N [username]</pre>
Exception	
First appearance	26-04-2019

Measure ID	2SU00046
Measure Title	Restrict FTP Users
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 2.1.2 and MSM-GSS-0002 2.1.12
Background	If FTP is running it needs to be secured
Measure	Restrict FTP Use

Implementation	If FTP is permitted to be used on the system, the file <code>/etc/ftpd/ftpusers</code> is used to specify a list of users who are not allowed to access the system via FTP. The following users must be added (if existent on the server): root, bin, daemon, sys, adm, lp, sync, shutdown, halt, mail, news, uucp, operator, games, gopher, ftp, nobody, rpm, vcsa, dbus, ntp, canna, nscd, rpc, postfix, mailman, named, amanda, postgres, exim, sshd, rpcuser, nsfnobody, pvm, apache, xfs, gdm, htt, mysql, webalizer, mailnull, smmsp, squid, ldap, netdump, pcap, radiusd, radvd, quagga, wnn, dovecot, adm, uuco, quest, nobody, lpd, lp, invscout, snapp, ipsec, sshd, nobody4, aiuser, noaccess You should also add the atos personal userIDs and application ID's that does not need ftp access. On aix: <code>/etc/ftpusers</code>
Exception	None
First appearance	26-04-2019

Measure ID	2SU00047
Measure Title	ftp Warning Banner
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	If FTP is running it needs to be secured whit a warning banner
Measure	Enable a Warning Banner for the FTP service
Implementation	Only if FTP is permitted (and listening) on the system. AIX: Set: <code>dspcat -g /usr/lib/nls/msg/en_US/ftpd.cat > /tmp/ftpd.tmp</code> <code>sed "s/\\"%s FTP server (\%s) ready.\\"/%s Warning: Access for authorized persons only.\\"/" /tmp/ftpd.tmp > /tmp/ftpd.msg</code> <code>gencat /usr/lib/nls/msg/en_US/ftpd.cat /tmp/ftpd.msg</code> <code>rm /tmp/ftpd.tmp /tmp/ftpd.msg</code> check: <code>dspcat -g /usr/lib/nls/msg/en_US/ftpd.cat grep "Warning: Access for authorized persons only."</code> Remediation: Ensure that the <code>bos.msg.en_US.net.tcp.client</code> fileset is installed: <code>lsipp -L "bos.msg.en_US.net.tcp.client"</code> NOTE: If the fileset is not installed, install it from the AIX media or another software repository. The fileset should reflect the language used on the server. HP: Add a '-a' option to the end of the ftp line in the <code>/etc/inetd.conf</code> file.

	For example: <pre>ftp stream tcp nowait root /usr/sbin/ftpd ftpd -l -a</pre> Add a message or banner line to the /etc/ftpd/ftpaccess file. "Warning: Access for authorized persons only." Reread the /etc/inetd.conf file: inetd -c Linux: Vsftpd ftp: Check line in file /etc/vsftpd.conf ftpd_banner=" Warning: Access for authorized persons only." Or banner_file=/etc/banners/ftp.msg where the file listed contains the "Warning: Access for authorized persons only." Sun: Remediation: Perform the following to implement the recommended state: echo "DisplayConnect /etc/issue" >> /etc/proftpd.conf svcadm restart ftp Audit: Perform the following to verify that the result is as recommended: grep "DisplayConnect" /etc/proftpd.conf DisplayConnect /etc/issue /etc/issue must contains "Warning: Access for authorized persons only"
Exception	All servers that does not have FTP listening to remote hosts.
First appearance	26-04-2019

Measure ID	2SU00048
Measure Title	Disable user-mountable removable media (ie automountd).
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 2.5.4
Background	Autofs/automount allows automatic mounting of devices, typically including CD/DVDs and USB drives.
Measure	With automounting enabled anyone with physical access could attach a USB drive or disc and have its contents available in system even if they lacked permissions to mount it themselves.
Implementation	AIX: To stop the automount daemon stopsrc -s automountd If, for some reason, the automountd daemon was started without the use of of kill automountd_PID

	where automountd_PID is the process ID of the automountd daemon. (Running the ps -e command displays the process ID of the automountd daemon.) The kill command sends a SIGTERM signal to the automountd daemon. test: ps -ef grep automountd HP: Fix: /sbin/init.d/autofs stop (and make sure it is not restarted after a reboot) Pre 11.31: To disable automountd in HP-UX configure the file /etc/rc.config.d/nfsconf and change the value for the AUTOFS parameter from 1 to 0 first: Then restart the NFS client: <pre># /sbin/init.d/nfs.client stop ... # /sbin/init.d/nfs.client start</pre> Test: ps -ef grep automountd Linux: Fix:: Run the following command to disable autofs : <pre># systemctl disable autofs</pre> test: Run the following command and verify result is not "enabled": <pre>systemctl list-unit-files grep enabled autofs must be disabled</pre> Suse Change auto in noauto in /etc/fstab Make sure there is not "auto" in /etc/fstab Sun: To disable this service, run the following commands: <pre>svcadm disable svc:/system/filesystem/rmvolmgr # svcadm disable svc:/network/rpc/smserver</pre> Test: Perform the following and verify that the result is as shown: <pre># svcs -Ho state svc:/system/filesystem/rmvolmgr disabled # svcs -Ho state svc:/network/rpc/smserver disabled</pre>
Exception	None
First appearance	26-04-2019

Measure ID	2SU00049
Measure Title	Disable USB services unless otherwise required
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 2.5.12
Background	The FAT filesystem format is primarily used on older windows systems and portable USB drives or flash modules. It comes in three types FAT12 , FAT16 , and FAT32 all of which are supported by the vfat kernel module.
Measure	Removing support for unneeded filesystem types reduces the local attack surface of the system. If this filesystem type is not needed, disable it
Implementation	AIX n.a. if automount is disabled there is no security risk on servers HP: n.a. if automount is disabled there is no security risk on servers LINUX: Edit or create the file /etc/modprobe.d/CIS.conf and add the following line: install vfat /bin/true Run the following command to unload the vfat module: <pre># rmmod vfat</pre> Impact: FAT filesystems are often used on portable USB sticks and other flash media are commonly used to transfer files between workstations, removing VFAT support may prevent the ability to transfer files in this way. Disabling the vfat module can prevent boot on UEFI systems TEST Run the following commands and verify the output is as indicated: <pre>modprobe -n -v vfat install /bin/true</pre> lsmod grep vfat <No output> RHEL 8: Edit or create the file /etc/modprobe.d/vfat.conf and add the following line: install vfat /bin/true Run the following command to unload the vfat module: <pre># rmmod vfat</pre> TEST Run the following commands and verify the output is as indicated: <pre>modprobe -n -v vfat install /bin/true</pre> lsmod grep vfat <No output> SUN n.a. if automount is disabled there is no security risk on servers

Exception	If for sap UEFI is used as boot mode (requirement of SAP) not disable vfat.
First appearance	26-04-2019

Measure ID	2SU00050
Measure Title	World-writable OS directories must have the sticky bit set
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 2.5.17
Background	OS directories must be protected by unauthorized users.
Measure	World-writable OS directories must have the sticky bit set.
Implementation	Check the following OS directory's that the sticky bits set <pre>/tmp /etc /var /proc /bin /root /admin /opt /appl /home</pre> NFS shares are excluded in the Alcatraz scan as they do not contain the os related directory's and can create performance issues. Test: Aix: Check the filesystemtype in /etc/filesystems and only use this filesystemtype in the find command <pre>/usr/bin/find [Directory] -fstype [fstype] -type d \(-perm -o+w -a ! -perm -1000 \) -print</pre> example: <pre>grep -p /opt: /etc/filesystems grep vfs vfs = jfs2 /usr/bin/find /opt/ -fstype jfs2 -type d \(-perm -o+w -a ! -perm -1000 \) -print</pre> Others: <pre>sudo find [Directory] ! -fstype nfs -type d \(-perm -o+w -a ! -perm -1000 \) -print</pre>
Exception	World-writable non OS directories (without the sticky bit) will be reported on request, to the responsible manager for the contract, the responsible manager needs to arrange that the applicable group check if the world-writable directories are needed. This measure is about os Directory's, directory's for application having a own TSS can be excluded ad the application TSS is checking the permissions for the application.

	NFS shares are excluded in the Alcatraz scan as they do not contain the os related directory's and can create performance issues. Manual scans over nfs can be done on request of customer. But are not reported in Tosca
First appearance	26-04-2019

Measure ID	2SU00051
Measure Title	Ssh HMAC algorithms
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	This variable limits the types of MAC algorithms that SSH can use during communication.
Measure	. MD5 and 96-bit MAC algorithms are considered weak and have been shown to increase exploitability in SSH downgrade attacks. Weak algorithms continue to have a great deal of attention as a weak spot that can be exploited with expanded computing power. An attacker that breaks the algorithm could take advantage of a MiTM position to decrypt the SSH tunnel and capture credentials and information
Implementation	Make sure you have updated openssh package to latest available version. add or modify the "MACs" line in /etc/ssh/sshd_config Disable any 96-bit HMAC Algorithms. Disable any MD5-based HMAC Algorithms Disable SHA1 based HMAC Algorithms Use for example SHA-224, SHA-256, SHA-512 as HMAC Exaple for ssh version 7.5: MACs umac-64-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,umac-64@openssh.com,umac-128@openssh.com,hmac-sha2-256,hmac-sha2-512
Exception	None
First appearance	26-04-2019

Measure ID	2SU00052
Measure Title	Ssh ciphers
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	This variable limits the types of ciphers that SSH can use during communication.
Measure	On most systems, OpenSSH supports AES, ChaCha20, Blowfish, CAST128, IDEA, RC4, and 3DES. AES and ChaCha20 are best ciphers currently supported, Arcfour, or RC4 are very insecure... Blowfish had some security alerts last years, cast128 and IDEA are old so if AES does not work this is the beast alternative. (only allowed via risk management.) Atos states to use only AES and ChaCha20.
Implementation	Make sure you have updated openssh package to latest available version.

	add or modify the "Ciphers" line in /etc/ssh/sshd_config Disable any CBC, Arcfour and RC4 ciphers Disable Blowfish, IDEA, and CAST128 Use for AES or ChaCha20. Example for ssh version 7.5: Ciphers aes128-ctr,aes192-ctr,aes256-ctr Or Ciphers aes128-ctr,aes192-ctr,aes256-ctr,chacha20-poly1305@openssh.com,aes128-gcm@openssh.com,aes256-gcm@openssh.com
Exception	None
First appearance	26-04-2019

Measure ID	2SU00053
Measure Title	Forbidden User files
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 2.5.11
Background	Do not store password unencrypted
Measure	.netrc files are forbidden on the server, all home directory's. On a server must be checked
Implementation	Check all users home dir that there is no .netrc file
Exception	None
First appearance	06-08-2019

Measure ID	2SU00054
Measure Title	Bash ShellShock
Classification	MODERATE
Baseline Reference	No Baseline reference
Background	Old bash versions have a vulnerability that needs to be solved (by removing old version and installing newer versions if needed)
Measure	Old Bash versions are forbidden on the server
Implementation	Check only if bash is installed on the server The path of bash can variate x='()' { : }; echo VULNERABLE' bash -c : if replay VULNERABLE the bash needs to be upgraded. Fix: Upgrade Bash
Exception	None
First appearance	06-08-2019

Measure ID	3SU00055
------------	----------

Measure Title	private keys without Passphrase
Classification	CRITICAL
Baseline Reference	No Baseline reference
Background	Private ssh key must include a Passphrase, to protect use form unauthorized persons
Measure	Private keys need to be stored only on the source server and keys needs to be protected by a passphrase
Implementation	Create new key pair including passphrase Distribute public key to target servers Remove old public key form target servers Remove old private key form source server Check: Check for all users the private key located in ~[username]/.ssh/ All private key files are named: id_rsa, id_dsa, id_* keys must contain, between the -----BEGIN and -----END lines per key, the 2 lines starting whit Proc-Type: DEK-Info:
Exception	Users that are not used for personal login (tty login) like application, server, monitoring, interface ore management users may have a private key whiteout a passphrase if needed (limited to the servers where it is needed.) Exceptions must be documented and suppressed in itcdb/tosca)
First appearance	06-08-2019

Measure ID	2SU00056
Measure Title	SSH Kex Algorithm
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	This variable limits the types of Kex algorithms that SSH can use during communication.
Measure	SHA1 Key algorithms are considered weak and have been shown to increase exploitability in SSH downgrade attacks. Weak algorithms continue to have a great deal of attention as a weak spot that can be exploited with expanded computing power.
Implementation	Make sure you have updated openssh package to latest available version. add or modify the " KexAlgorithms" line in /etc/ssh/sshd_config Disable any sha1 KexAlgorithms like: - diffie-hellman-group-exchange-sha1 - diffie-hellman-group1-sha1 - diffie-hellman-group14-sha1 - ecdh-sha2-nistp384 - gss-gex-sha1-* - gss-group1-sha1-* - rsa1024-sha1 a subset of the following approved keys (ore newer keys) must be configured:

Kommentiert [ZM1]: Tom to check

	• curve25519-sha256 • curve25519-sha256@libssh.org • diffie-hellman-group-exchange-sha256 • diffie-hellman-group14-sha256 • diffie-hellman-group16-sha512 • diffie-hellman-group18-sha512 • ecdh-sha2-nistp256 • ecdh-sha2-nistp384 • gss-group14-sha256-* • gss-group16-sha512-* • gss-nistp256-sha256-* • gss-nistp384-sha384-* • gss-curve25519-sha256-* Example for ssh: KexAlgorithms ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256, diffie-hellman-group16-sha512 The Implement column is the current recommendations of this RFC. Key Exchange Method Names are listed alphabetically.
Exception	None
First appearance	24-05-2021

Measure ID	2SU10001
Measure Title	Alcatraz Compliance Scanning Check Server Unix
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	Provide the ability to assess the deployment rate of the Alcatraz Compliance Management Solution, where the monitoring tools are already installed/available
Measure	Check Alcatraz Compliance Management Solution deployment – compliance scanning enabled: yes/no.
Implementation	Implemented as part of the Alcatraz scripting framework
Exception	None
First appearance	08-04-2019

Appendix A Checklist

An editable Security check sheet in Excel format can be found on SharePoint at location:
<https://sp.myatos.net/ms/gbf/gadp/TSSD/TSS Manual Checklists>

Measure ID	Measure title	Alcatraz	Checked
3SU00001	Password Maximum Age	YES	
3SU00004	Blank Passwords Are Not Allowed	YES	
3SU00005	All passwords must match a certain level of complexity	YES	
2SU00006	Previously Used Passwords (Password: History)	YES	
3SU00007	All passwords must have a minimum length of 15 characters	YES	
3SU00008	Enable auth logging subsystem to log all auth events	YES	
3SU00009	Monitor System Files for Ownership and Permissions	YES	
3SU00010	Actively Monitor System Files: /etc/profile	YES	
3SU00014	Disallow Root login via SSH	YES	
3SU00016	SSH Protocol 2 Enforced	YES	
2SU00017	SSH "Rhosts" Functionality Disabled	YES	
2SU00018	Home Directory Ownership	YES	
2SU00019	Home Directory Permissions	YES	
3SU00021	Service Configuration: IP Stack settings SourceRouting, IpRedirects.	YES	
2SU00022	Log Data Retention: System Logs (syslog)	YES	
2SU00023	Crontab file ownership	YES	
2SU00024	Ownership: root umask	YES	
3SU00025	OS password encryption	YES	
2SU00027	Disable SAMBA on RHEL systems unless needed	YES	
3SU00028	Service Hardening: Disable 'R' daemons and Telnet daemon	YES	
2SU00030	Service Hardening: Disable Sendmail / MTA Unless Needed	YES	
2SU00031	Service Hardening: Disable NIS	YES	
2SU00032	Service Hardening: SNMP Community Names	YES	
3SU00033	Service Hardening: SNMP Version	YES	
2SU00034	Ensure .rhost authentication is disabled in PAM	YES	
3SU00035	Ensure NTP Client is running on all Unix Computers	YES	
3SU00036	Ensure NTP clock does not drift significantly from a trusted time source	YES	
3SU00037	Verify that NFS, if used, is configured securely, with nosuid and anonymous UID not equal to 0	YES	
2SU00038	Logging and timestamps for issued commands	YES	
2SU00039	Login Banners	YES	
3SU00040	Service Hardening: Sendmail	YES	

Measure ID	Measure title	Alcatraz	Checked
3SU00041	Max Login Retries	YES	
2SU00042	Duplicate UID/GID	YES	
2SU00043	Root path	YES	
2SU00044	Cron/AT allow	YES	
2SU00045	System Account Default Passwords/ lockdown	YES	
2SU00046	Restrict FTP Users	YES	
2SU00047	ftp Warning Banner	YES	
2SU00048	Disable user-mountable removable media (ie automountd).	YES	
2SU00049	Disable USB services unless otherwise required	YES	
2SU00050	World-writable OS directories must have the sticky bit set	YES	
2SU00051	Ssh HMAC algorithms	YES	
2SU00052	SSH ciphers	YES	
2SU00053	Forbidden User files	YES	
2SU00054	Bash ShellShock	YES	
3SU00055	private keys without Passphrase	YES	
2SU00056	SSH Kex Algorithm	yes	
2SU10001	Alcatraz Compliance Scanning Check Server Unix	NO	